

第 13 章

入侵检测技术

13.1

入侵检测概述

入侵检测系统(Intrusion Detection System, IDS)的发展已有 30 年历史。1980 年 4 月, James P. Anderson 为美国空军做了一份题为“Computer Security Threat Monitoring and Surveillance”(计算机安全威胁监控与监视)的技术报告, 第一次详细阐述了入侵检测的概念。他提出了一种对计算机系统风险和威胁进行分类的方法, 并将威胁分为外部渗透、内部渗透和不法行为 3 种, 还提出了利用审计跟踪数据监视入侵活动的思想。这份报告被公认为是入侵检测的开山之作。

从 1984 年到 1986 年, 乔治敦大学的 Dorothy Denning 和 SRI/CSL (SRI 公司计算机科学实验室) 的 Peter Neumann 研究设计了一个实时入侵检测系统模型, 取名为入侵检测专家系统(Intrusion Detection Expert System, IDES)。该模型由 6 个部分组成: 主体、对象、审计记录、轮廓特征、异常记录和活动规则。1988 年, SRI/CSL 的 Teresa Lunt 等人改进了 Denning 的入侵检测模型, 并开发出了一个新型的 IDES。该系统包括一个异常探测器和一个专家系统, 分别用于统计异常模型的建立和基于规则的特征分析检测。

1990 年是入侵检测系统发展史上的一个分水岭, 加州大学戴维斯分校的 L.T. Heberlein 等人开发出了网络安全监视器(Network Security Monitor, NSM)。该系统第一次直接将网络流作为审计数据来源, 因而可以在不将审计数据转换成统一格式的情况下监控异种主机。此后, 入侵检测系统发展史翻开了新的一页, 两大阵营正式形成: 基于网络的 IDS 和基于主机的 IDS。

IDS 不间断地从计算机网络或计算机系统上的若干关键点上收集信息, 集中或分布地分析信息, 判断来自网络内部和外部的入侵企图, 并实时发出报警。IDS 的主要作用是:

- 通过检测和记录网络中的攻击事件, 阻断攻击行为, 防止入侵事件的发生。
- 检测其他未授权操作或安全违规行为。
- 统计分析黑客在攻击前的探测行为, 预先给管理员发出警报。
- 报告计算机系统或网络中存在的安全威胁。
- 提供有关攻击的详细信息, 帮助管理员诊断和修补网络中存在的安全弱点。
- 在大型复杂的计算机网络中部署入侵检测系统, 提高网络安全管理的质量。

13.1.1 入侵检测的概念

入侵（Intrusion）是个广义概念，它不仅包括攻击者（如恶意的黑客）非法取得系统的控制权的行为，也包括他们对系统漏洞信息的收集，并由此对信息系统造成危害的行为。

美国国家安全通信委员会（NSTAC）下属的入侵检测小组（IDSG）在 1997 年给出的关于“入侵检测”（Intrusion Detection）的定义是：入侵检测是对企图入侵、正在进行的入侵或已经发生的入侵行为进行识别的过程。

关于“入侵检测”的定义，人们还有很多不同的提法，其中包括如下几种说法：

（1）检测对计算机系统的非授权访问。

（2）对系统的运行状态进行监视，发现各种攻击企图、攻击行为或攻击结果，以保证系统资源的保密性、完整性和可用性。

（3）识别针对计算机系统和网路系统或广义上的信息系统的非法攻击，包括检测外部非法入侵者的恶意攻击或探测，以及内部合法用户越权使用系统资源的非法行为。

所有能够执行入侵检测任务和实现入侵检测功能的系统都可称为入侵检测系统（Intrusion Detection System, IDS），其中包括软件系统或软、硬件结合的系统。一个通用的入侵检测系统模型如图 13-1 所示。

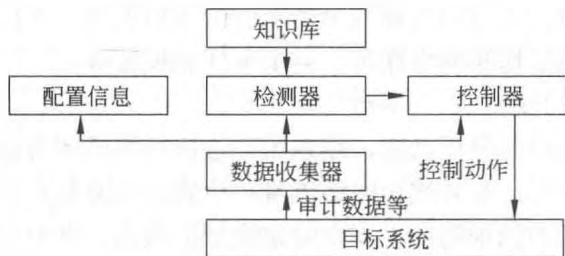


图 13-1 通用的入侵检测系统模型

在图 13-1 中，通用入侵检测系统模型主要由 4 个部分组成。

（1）数据收集器（又称探测器）。主要负责收集数据。探测器的输入数据流包括任何可能包含入侵行为线索的系统数据，如各种网络协议数据包、系统日志文件和系统调用记录等。探测器将这些数据收集起来，然后再发送到检测器进行处理。

（2）检测器（又称分析器或检测引擎）。负责分析和检测入侵的任务，并向控制器发出警报信号。

（3）知识库。为检测器和控制器提供必需的数据信息支持。这些信息包括：用户历史活动档案或检测规则集合等。

（4）控制器。根据从检测器发来的警报信号，人工或自动地对入侵行为做出响应。

此外，大多数入侵检测系统都会包含一个用户接口组件，用于观察系统的运行状态和输出信号，并对系统的行为进行控制。

13.1.2 IDS 的主要功能

入侵检测是对传统安全产品的合理补充，帮助系统对付网络攻击，扩展了系统管理员的安全管理能力（包括安全审计、监视、进行识别和响应），提高了信息安全基础结构的完整性。它从计算机网络系统中的若干关键点收集信息，并分析这些信息，查看网络中是否有违反安全策略的行为和遭到袭击的迹象。入侵检测被认为是防火墙之后的第二道安全闸门，能在不影响网络性能的情况下对网络进行监测，从而提供对内部攻击、外部攻击和误操作的实时保护。以上功能都是通过执行以下任务来实现：

- (1) 监视、分析用户及系统的活动。
- (2) 系统构造和弱点的审计。
- (3) 识别反映已知进攻的活动模式并向相关人员报警。
- (4) 异常行为模式的统计分析。
- (5) 评估重要系统和数据文件的完整性。
- (6) 操作系统的审计跟踪管理，并识别用户违反安全策略的行为。

对于一个成功的入侵检测系统来说，它不但可以使系统管理员时刻了解网络系统（包括程序、文件和硬件设备）的任何变更，还能给网络安全策略的制定提供依据。更为重要的是，它应该易于管理、配置简单，即使非专业人员也易于使用。而且，入侵检测的规模还应根据网络威胁、系统构造和安全需求的改变而改变。入侵检测系统在发现入侵后会及时做出响应，包括切断网络连接、记录事件和报警等。

IDS 的主要功能如下：

- (1) 网络流量的跟踪与分析功能。跟踪用户进出网络的所有活动，实时检测并分析用户在系统中的活动状态；实时统计网络流量，检测拒绝服务攻击等异常行为。
- (2) 已知攻击特征的识别功能。识别特定类型的攻击，并向控制台报警，为防御提供依据。根据定制的条件过滤重复警报事件，减轻传输与响应的压力。
- (3) 异常行为的分析、统计与响应功能。分析系统的异常行为模式，统计异常行为，并对异常行为做出响应。
- (4) 特征库的在线和离线升级功能。提供入侵检测规则在线和离线升级，实时更新入侵特征库，不断提高 IDS 的入侵检测能力。
- (5) 数据文件的完整性检查功能。检查关键数据文件的完整性，识别并报告数据文件的改动情况。
- (6) 自定义的响应功能。定制实时响应策略；根据用户定义，经过系统过滤，对警报事件及时响应。
- (7) 系统漏洞的预报警功能。对未发现的系统漏洞特征进行预报警。
- (8) IDS 探测器集中管理功能。通过控制台收集探测器的状态和报警信息，控制各个探测器的行为。

一个高质量的 IDS 产品除了具备以上入侵检测功能外，还必须具备较高的可管理性和自身安全性等功能。

13.1.3 IDS 的任务

1. 信息收集

IDS 的第一项任务是信息收集。IDS 所收集的信息内容包括用户（合法用户和非法用户）在网络、系统、数据库及应用系统中活动的状态和行为。为了准确地收集用户的信息活动，需要在信息系统中的若干个关键点（包括不同网段、不同主机、不同数据库服务器、不同应用服务器等处）设置信息探测点。

IDS 可利用的信息来源如下：

（1）系统和网络的日志文件

日志文件中包含发生在系统和网络上的异常活动的证据。通过查看日志文件，能够发现黑客的入侵行为。

（2）目录和文件中的异常改变

信息系统中的目录和文件中的异常改变（包括修改、创建和删除），特别是那些限制访问的重要文件和数据的改变，很可能就是一种入侵行为。黑客经常替换、修改和破坏他们获得访问权的系统上的文件，替换系统程序或修改系统日志文件，达到隐藏他们活动痕迹的目的。

（3）程序执行中的异常行为

信息系统上的程序执行一般包括操作系统、网络服务、用户启动程序和特定目的的应用。每个在系统上执行的程序由一个或多个进程来实现。每个进程执行在具有不同权限的环境中，这种环境控制着进程可访问的系统资源、程序和数据文件等。一个进程出现了异常的行为，表明黑客可能正在入侵系统。

（4）物理形式的入侵信息

物理形式的入侵包括两个方面的内容：一是对网络硬件的非授权连接；二是对物理资源的未授权访问。黑客会想方设法去突破网络的周边防卫，如果他们能够在物理上访问内部网，就能安装他们自己的设备和软件。依此，黑客就可以知道网上存在的不安全（或未授权使用）的设备，然后利用这些设备访问网络资源。

2. 信息分析

对收集到的上述 4 类信息，包括网络、系统、数据及用户活动的状态和行为信息等进行模式匹配、统计分析和完整性分析，得到实时检测所必需的信息。

（1）模式匹配

模式匹配技术，即模式发现技术，就是将收集到的信息与已知的网络入侵模式的特征数据库进行比较，从而发现违背安全策略的行为。假定所有入侵行为和手段（及其变种）都能够表达为一种模式或特征，那么所有已知的入侵方法都可以用匹配的方法来实现。模式匹配的关键是如何表达入侵模式，把入侵行为与正常行为区分开来。模式匹配的优点是误报率小，其局限性是只能发现已知攻击，却对未知攻击无能为力。

（2）统计分析

统计分析是入侵检测常用的异常发现方法。假定所有入侵行为都与正常行为不同，

如果能建立系统正常运行的行为轨迹，那么就可以把所有与正常轨迹不同的系统状态视为可疑的入侵企图。统计分析方法就是先创建系统对象（如用户、文件、目录和设备等）的统计属性（如访问次数、操作失败次数、访问地点、访问时间、访问延时等），再将信息系统的实际行为与统计属性进行比较。当观察值在正常值范围之外时，则认为有入侵行为发生。统计分析模型常用的测量参数包括审计事件的数量、间隔时间、资源消耗情况等。

常用的5种入侵检测统计模型如下：

① **操作模型**。该模型假设可将测量结果与一些固定指标比较来发现异常，固定指标可以根据经验值或一段时间内的统计平均值获得。例如，在短时间内的多次失败的登录很有可能是口令猜测攻击。

② **方差**。该模型计算参数的方差，设定其置信区间，当测量值超过置信区间的范围时，表明可能有异常事件。

③ **多元模型**。该模型是操作模型的扩展，通过同时分析多个参数实现检测。

④ **马尔柯夫过程模型**。该模型将每种类型的事件定义为系统状态，用状态转移矩阵来表示状态的变化。当一个事件发生时，若在状态矩阵中该事件的转移概率较小，则可能是异常事件。

⑤ **时间序列分析**。该模型将事件计数与资源耗用根据时间排成序列，如果一个新事件在该时间发生的概率较低，则该事件可能是入侵。

统计分析方法的最大优点是它可以“学习”用户的使用习惯，从而具有较高检出率与可用性，缺点是误报率较高，且不适应用户正常行为的突然改变。

（3）完整性分析

完整性分析检测某个文件或对象是否被更改。完整性分析常利用杂凑函数（例如SHA-256），它能识别微小的变化。该方法的优点是只要某个文件或对象有任何改变，都能够被发现。缺点是当完整性分析未开启时，不能主动发现入侵行为。

3. 安全响应

IDS 在发现入侵行为后会及时做出响应，包括终止网络服务、记录事件日志、报警和阻断等。响应可分为主动响应和被动响应两种类型。主动响应由用户驱动或系统本身自动执行，可对入侵行为采取终止网络连接、修正系统环境（如修改防火墙的安全策略）等；被动响应包括发出告警信息和通知等。

目前比较流行的响应方式有记录日志、实时显示、E-mail 报警、声音报警、SNMP 报警、实时 TCP 阻断、防火墙联动、WinPop 显示、手机短信报警等。

13.1.4 IDS 的评价标准

一个较为完整的入侵检测系统的评价标准集合应该包括3个方面的内容：性能测试、功能测试和用户可用性测试。性能测试主要衡量入侵检测系统在高工作负荷条件下的运行情况。例如，数据包截获和过滤的速度，是否出现丢包现象，以及检测引擎的总体吞吐量等。功能测试衡量入侵检测系统自身功能特征，如系统的架构是否支持可扩展性、

是否支持规则定制功能、是否能够检测到集中所有的攻击样本的测试样本、警报系统的功能是否强大及是否提供强大友好的报表功能等。用户可用性测试则是衡量用户在使用某个入侵检测系统时的操作友好性,如界面设计是否合理、使用是否方便等。综合来说,一个好的 IDS 应该具有以下基本特性:

- (1) 先进的检测能力和响应能力。
- (2) 不影响被保护网络环境中主机和各应用系统的正常运行。
- (3) 在无人监督管理的情况下,能够连续不断地正常运行。
- (4) 具有坚固的自身安全性。
- (5) 具有很好的可管理性。
- (6) 消耗系统资源较少。
- (7) 可扩展性好,能适应网络环境 and 应用系统的变化。
- (8) 支持 IP 碎片重组。
- (9) 支持 TCP 流重组。
- (10) 支持 TCP 状态检测。
- (11) 支持应用层协议解码。
- (12) 灵活、可扩展、可配置的用户报告功能。
- (13) 安装、配置、调整简单易行。
- (14) 能与常用的其他安全产品集成。
- (15) 支持常用的网络协议和拓扑结构等。

13.2

入侵检测原理及主要方法

13.2.1 异常检测基本原理

异常检测技术又称为基于行为的入侵检测技术,用来识别主机或网络中的异常行为。它假设攻击与正常的(合法的)活动有明显的差异。异常检测首先收集一段时间操作活动的历史数据,再建立代表主机、用户或网络连接的正常行为描述,然后收集事件数据并使用一些不同的方法来决定所检测到的事件活动是否偏离了正常行为模式,从而判断是否发生了入侵。异常检测模型的结构如图 13-2 所示。

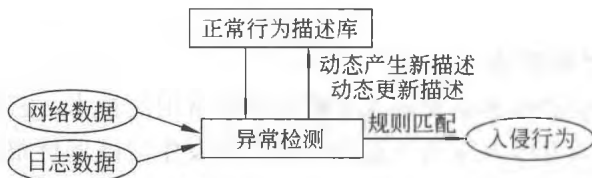


图 13-2 异常检测模型的结构

基于异常检测原理的入侵检测方法有以下几种:

- (1) 统计异常检测方法。

- (2) 特征选择异常检测方法。
- (3) 基于贝叶斯推理异常检测方法。
- (4) 基于贝叶斯网络异常检测方法。
- (5) 基于模式预测异常检测方法。

其中，比较成熟的方法是统计异常检测方法和特征选择异常检测方法。目前，已经有根据这两种方法开发而成的软件产品面市，其他方法目前还停留在理论研究阶段。

13.2.2 误用检测基本原理

误用检测技术又称基于知识的检测技术。它假定所有入侵行为和手段（及其变形）都能够表达为一种模式或特征，并对已知的入侵行为和手段进行分析，提取检测特征，构建攻击模式或攻击签名，通过系统当前状态与攻击模式或攻击签名的匹配判断入侵行为。误用检测模型的结构如图 13-3 所示。

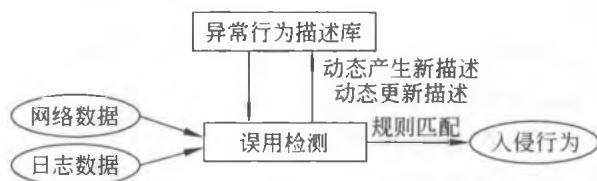


图 13-3 误用检测模型的结构

误用检测技术的优点在于可以准确地检测已知的入侵行为，缺点是不能检测未知的入侵行为。误用检测的关键在于如何表达入侵行为，即攻击模型的构建，把真正的入侵与正常行为区分开来。基于误用检测原理的入侵检测方法有以下几种：

- (1) 基于条件的概率误用检测方法。
- (2) 基于专家系统误用检测方法。
- (3) 基于状态迁移分析误用检测方法。
- (4) 基于键盘监控误用检测方法。
- (5) 基于模型误用检测方法。

13.2.3 各种入侵检测技术

当前在网络安全实践中存在多种入侵检测技术，下面分别对一些常见的入侵检测技术进行简要介绍。

1. 基于概率统计的检测

基于概率统计的检测技术是异常入侵检测中最常用的技术，它对用户历史行为建立模型。根据该模型，当 IDS 发现有可疑的用户行为发生时就保持跟踪，并监视和记录该用户的行为。这种方法的优越性在于它应用了成熟的概率统计理论；缺点是由于用户行为非常复杂，因而要想准确地匹配一个用户的历史行为非常困难，易造成系统误报、错报和漏报。定义入侵阈值比较困难，阈值高则误检率提高，阈值低则漏检率提高。

SRI (Stanford Research Institute) 研制开发的 IDES 是一个典型的实时监测系统。

IDES 能根据用户以前的历史行为生成每个用户的历史行为记录库,并能自适应地学习被检测系统中每个用户的行为习惯。当某个用户改变其行为习惯时,这种异常就被检测出来。这种系统具有固有的弱点,例如,用户的行为非常复杂,因而要想准确地匹配一个用户的历史行为和当前行为是非常困难的。这种方法的一些假设是不准确或不贴切的,容易造成系统误报、错报或漏报。

在这种实现方法中,检测器首先根据用户对象的动作为每一个用户都建立一个用户特征表,通过比较当前特征和已存储的以前特征判断是否有异常行为。用户特征表需要根据审计记录情况不断更新。在 SRI 的 IDES 中给出了一个特征简表的结构: {变量名,行为描述,例外情况,资源使用,时间周期,变量类型,阈值,主体,客体,特征值},其中,变量名、主体、客体唯一确定了特征简表,特征值由系统根据审计数据周期产生。这个特征值是所有有悖于用户特征的异常程度值的函数。

这种方法的优越性在于能应用成熟的概率统计理论,不足之处在于:

(1) 统计检测对于事件发生的次序不敏感,完全依靠统计理论,可能会漏掉那些利用彼此相关联事件的入侵行为。

(2) 定义判断入侵的阈值比较困难,阈值太高则误检率提高,阈值太低则漏检率提高。

2. 基于神经网络的检测

基于神经网络的检测技术的基本思想是用一系列信息单元训练神经单元,在给定一个输入后,就可能预测出输出。它是对基于概率统计的检测技术的改进,主要克服了传统统计分析技术的一些问题。

基于神经网络的模块,将当前命令和刚过去的 W 个命令组成了网络的输入,其中, W 是神经网络预测下一个命令时所包含的过去命令集的大小。根据用户代表性命令序列训练网络后,该网络就形成了相应的用户特征表。网络对下一事件的预测错误率在一定程度上反映了用户行为的异常程度。这种方法的优点在于能够更好地处理原始数据的随机特性,即不需要对这些数据做任何统计假设并有较好的抗干扰能力;缺点是网络的拓扑结构及各元素的权值很难确定,命令窗口的 W 值也很难选取。窗口太大,网络效率降低;窗口太小,网络输出不理想。

目前,神经网络技术提出了对基于传统统计技术的攻击检测方法的改进方向,但尚不十分成熟,所以传统的统计方法仍继续发挥作用,仍然能为发现用户的异常行为提供相当有参考价值的信息。

3. 基于专家系统的检测

安全检测工作自动化的另外一个值得重视的研究方向就是基于专家系统的攻击检测技术,即根据安全专家对可疑行为的分析经验来形成一套推理规则,然后再在此基础上建立相应的专家系统。专家系统对所涉及的攻击操作自动进行分析工作。

所谓专家系统,是基于一套由专家经验事先定义的规则的推理系统。例如,某个用户在数分钟之内连续进行登录,且失败超过 3 次,专家系统就可以认为是一种攻击行为。类似的规则在统计系统中似乎也有,但要注意的是基于规则的专家系统或推理系统也有

其局限性，因为作为这类系统的基础推理规则一般都是根据已知的安全漏洞进行安排和策划的，而对系统的最危险的威胁则主要来自未知的安全漏洞。实现基于规则的专家系统是一个知识工程问题，而且其功能应当能够随着经验的积累而利用其自学能力进行规则的扩充和修正。当然，这样的能力需要在专家的指导和参与下才能实现，否则可能会导致较多的错误。一方面，推理机制使得系统面对一些新的行为现象时可能具备一定的应对能力（即有可能发现一些新的安全漏洞）；另一方面，攻击行为也可能不会触发任何一个规则，从而被检测到。专家系统对历史数据的依赖性总的来说比基于统计技术的审计系统少，因此系统的适应性比较强，可以较灵活地适应广泛的安全策略和检测需求。但迄今，推理系统和谓词演算的可计算问题还未得到很好的解决。

在具体实现过程中，专家系统主要面临的问题是：

（1）全面性问题——很难从各种入侵检测手段中抽象出全面的规则化知识。

（2）效率问题——需要处理的数据量过大，而且在大型系统上很难获得实时、连续的审计数据。

4. 基于模型推理的检测

攻击者在攻击一个系统时往往采用一定的行为程序，如猜测口令的程序，这种行为程序构成了某种具有一定行为特征的模型，根据这种模型所代表的攻击意图的行为特征，可以实时地检测出恶意的攻击企图。用基于模型的推理方法，人们能够为某些行为建立特定的模型，从而能够监视具有特定行为特征的某些活动。根据假设的攻击脚本，这种系统就能够检测出非法的用户行为。为了准确判断，一般要为不同的攻击者和不同的系统建立特定的攻击脚本。

当有证据表明某种特定的攻击发生时，系统应收集其他证据来证实或否定攻击的真实性，既不能漏报攻击对信息系统造成实际损害，又能尽可能避免错报。

当然，上述几种方法都不能彻底解决攻击检测问题，最好是综合地利用各种手段强化计算机信息系统的安全程序，以增加攻击成功的难度，同时根据系统本身的特点选择适合的攻击检测手段。

5. 基于免疫的检测

基于免疫的检测技术是将自然免疫系统的某些特征运用到网络系统中，使整个系统具有适应性、自我调节性、可扩展性。人的免疫系统成功地保护人体不受各种抗原和组织的侵害，这个重要特性吸引了许多计算机安全专家和人工智能专家。通过学习免疫专家的研究成果，计算机专家提出了计算机免疫系统。在许多传统的网络安全系统中，每个目标都将它的系统日志和收集到的信息传送给相应的服务器，由服务器分析整个日志和信息，判断是否发生恶意入侵。基于免疫的入侵检测系统运用计算免疫的多层性、分布性、多样性等特性设置动态代理，实施分层检测和响应机制。

6. 入侵检测的新技术

数据挖掘技术被 Wenke.lee 用在了入侵检测中。用数据挖掘程序处理搜集到的审计数据，为各种入侵行为和正常操作建立精确的行为模式，这个过程是一个自动过程，不

需要人工分析和编码入侵模式。移动代理用于入侵检测中,具有应对主机间动态迁移、一定的智能性、与平台无关性、分布的灵活性、低网络数据流量和多代理合作特性。移动代理技术适用于大规模信息搜集和动态处理,在入侵检测系统中采用该技术,可以提高入侵检测系统的性能。

7. 其他相关问题

为了防止过多的不相干信息的干扰,用于安全目的的攻击检测系统在审计系统之外,还要配备适合系统安全策略的信息采集器或过滤器。同时,除了依靠来自审计子系统的信息,还应当充分利用来自其他信息源的信息。在某些系统内可以在不同层次进行审计跟踪。例如,有些系统的安全机制采用 3 级审计跟踪,包括审计操作系统核心调用行为、审计用户和操作系统界面级行为和审计应用程序内部行为。

另一个重要问题是决定入侵检测系统的运行位置。为了提高入侵检测系统的运行效率,可以安排在与被监视系统独立的计算机上执行审计跟踪分析和攻击性检测。因为监视系统的响应时间对被监视系统的运行完全没有负面影响,也不会因为其他安全有关的因素而受到影响,这样做既提高了效率,又保证了安全性。

总之,为了有效地利用审计系统提供的信息,通过攻击检测措施防范攻击威胁,计算机安全系统应当根据系统的具体条件选择适用的主要攻击检测方法,并且有机地融合其他可选用的攻击检测方法。同时,我们应当清醒地认识到,任何一种攻击检测措施都不能一劳永逸,必须配备有效的管理和组织措施。

人们对于安全技术的要求将越来越高。这种需求也刺激着攻击检测技术和其理论研究向前发展,同时也必将促进实际安全产品的进一步发展。

13.3

IDS 的结构与分类

通过对计算机网络或计算机系统内的若干关键点收集信息并进行分析,入侵检测系统从中发现网络或系统中是否有违反安全策略的行为和被攻击的迹象。进行入侵检测的软件与硬件的组合构成入侵检测系统。

入侵检测系统执行的主要任务包括监视、分析用户及系统活动;审计系统构造和弱点;识别、反映已知进攻的活动模式,向相关人员报警;统计分析异常行为模式;评估重要系统和数据文件的完整性;审计、跟踪管理操作系统,识别用户违反安全策略的行为。

入侵检测一般分为 3 个步骤:信息收集、数据分析和响应(被动响应和主动响应)。

(1) 信息收集

信息收集的内容包括系统、网络、数据用户活动的状态和行为。入侵检测利用的信息一般来自系统日志、目录及文件中的异常改变、程序执行中的异常行为及物理形式的入侵信息 4 个方面。

(2) 数据分析

数据分析是入侵检测的核心。它首先构建分析器,把收集到的信息经过预处理,建

立一个行为分析引擎或模型，然后向模型中植入时间数据，在知识库中保存植入数据的模型。数据分析一般通过模式匹配、统计分析和完整性分析3种方法进行。前两种方法用于实时入侵检测，而完整性分析则用于事后分析。数据分析采用5种统计模型：操作模型、方差、多元模型、马尔可夫过程模型和时间序列分析。统计分析的最大优点是可以学习用户的使用习惯。

（3）响应

入侵检测系统在发现入侵后会及时做出响应，包括切断网络连接、记录时间和报警等。响应一般分为主动响应（阻止攻击或影响，从而改变攻击的过程）和被动响应（报告和记录所检测出的问题）两种类型。主动响应由用户驱动或系统本身自动执行，可对入侵者采取行动（如断开连接）、修正系统环境或收集有用信息；被动响应则包括告警和通知、简单网络管理协议（SNMP）陷阱和插件等。另外，还可以按策略配置响应，分别采取立即、紧急、适时、本地的长期和全局的长期等行动。

13.3.1 IDS 的结构

通用入侵检测架构（Common Intrusion Detection Framework, CIDEF）阐述了入侵检测系统的通用模型。它将一个入侵检测系统分为以下组件：

- （1）事件产生器（Event Generators）。
- （2）事件分析器（Event Analyzers）。
- （3）响应单元（Response Units）。
- （4）事件数据库（Event Databases）。

CIDEF 将入侵检测系统需要分析的数据统称为事件（Event），它可以是基于网络的入侵检测系统中的网络数据包，也可以是基于主机的入侵检测系统从系统日志等其他途径得到的信息。它也对各部件之间的信息传递格式、通信方法和标准 API 进行了标准化。

事件产生器从整个计算环境中获得事件，并提供给系统的其他部分。事件分析器对得到的数据进行分析，并产生分析结果。响应单元则是对分析结果做出反应的功能单元，它可以做出切断连接、改变文件属性等强烈反应，甚至发动对攻击者的反击，或者报警。事件数据库是存放各种中间数据和最终数据的地方的统称，它可以是复杂的数据库，也可以是简单的文本文件。

一个入侵检测系统的功能结构如图 13-4 所示，它至少包含事件提取、入侵分析、入侵响应和远程管理 4 部分功能。

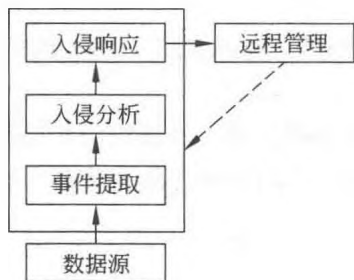


图 13-4 入侵检测系统的功能构成

在图 13-4 中，各部分功能如下：

- （1）事件提取功能负责提取与被保护系统相关的运行数据或记录，并负责对数据进行简单的过滤。
- （2）入侵分析的任务就是在提取到的运行数据中找出入侵的痕迹，区分授权的正常访问行为和非授权的不正常访问行为，分析入侵行为并对入侵者进行定位。
- （3）入侵响应功能在分析出入侵行为后被触发，根据入侵行为产生响应。

(4) 由于单个入侵检测系统的检测能力和检测范围有限,入侵检测系统一般采用分布监视、集中管理的结构,多个检测单元运行于网络中的各个网段或系统上,通过远程管理功能在一台管理站上实现统一的管理和监控。

13.3.2 IDS 的分类

1. 按照数据来源分类

根据数据来源的不同,IDS 可以分为以下 3 种基本结构。

(1) 基于网络的入侵检测系统 (Network Intrusion Detection System, NIDS)。数据来源于网络上的数据流。

NIDS 能够截获网络中的数据包,提取其特征并与知识库中已知的攻击签名相比较,从而达到检测目的。其优点是检测速度快、隐蔽性好、不易受到攻击、对主机资源消耗少;缺点是有些攻击是由服务器的键盘发出的,不经过网络,因而无法识别,误报率较高。

(2) 基于主机的入侵检测系统 (Host Intrusion Detection System, HIDS)。数据来源于主机系统,通常是系统日志和审计记录。

HIDS 通过对系统日志和审计记录的不断监控和分析来发现攻击后的误操作。优点是针对不同操作系统捕获应用层入侵,误报少;缺点是依赖于主机及其子系统,实时性差。

HIDS 通常安装在被保护的主机上,主要对该主机的网络实时连接及系统审计日志进行分析和检查,在发现可疑行为和安全违规事件时,向管理员报警,以便采取措施。

(3) 采用上述两种数据来源的分布式入侵检测系统 (Distributed Intrusion Detection System, DIDS)。

这种系统能够同时分析来自主机系统审计日志和网络数据流,一般为分布式结构,由多个部件组成。DIDS 可以从多个主机获取数据,也可以从网络传输取得数据,克服了单一的 HIDS、NIDS 的不足。

典型的 DIDS 采用控制台/探测器结构。NIDS 和 HIDS 作为探测器放置在网络的关键节点,并向中央控制台汇报情况。攻击日志定时传送到控制台,并保存到中央数据库中,新的攻击特征能及时发送到各个探测器上。每个探测器能够根据所在网络的实际需要配置不同的规则集。

2. 按照入侵检测策略分类

根据入侵检测的策略,IDS 也可以分成 3 种类型:滥用检测、异常检测、完整性分析。

(1) 滥用检测

滥用检测 (Misuse Detection) 就是将收集到的信息与已知的网络入侵和系统误用模式数据库进行比较,从而发现违背安全策略的问题。该方法的优点是只需收集相关的数据集合,可显著减少系统负担,且技术已相当成熟。该方法存在的弱点是需要不断地升级以对付不断出现的黑客攻击手段,不能检测到从未出现过的黑客攻击手段。

（2）异常检测

异常检测（Abnormal Detection）首先给系统对象（如用户、文件、目录和设备等）创建一个统计描述、统计正常使用时的一些测量属性（如访问次数、操作失败次数和延时等）。测量属性的平均值将被用来与网络、系统的行为进行比较，如果观察值在正常范围之外，就认为有入侵发生。其优点是可检测到未知的入侵和更加复杂的入侵。缺点是误报、漏报率高，且不适应用户正常行为的突然改变。

（3）完整性分析

完整性分析（Integrity Analysis）主要关注某个文件或对象是否被更改，这通常包括文件和目录的内容及属性，它在发现更改或特洛伊木马应用程序方面特别有效。其优点是只要成功的攻击导致了文件或其他对象的任何改变，它都能发现；缺点是一般以批处理方式实现，不易于实时响应。

在下面的讨论中，将按照第一种分类方法分别讨论 NIDS、HIDS 和 DIDS。

13.4 NIDS

随着计算机网络技术的发展，单独依靠主机审计入侵检测难以适应网络安全需要。在这种情况下，人们提出了基于网络的入侵检测系统体系结构，这种检测系统根据网络流量、网络数据包和协议来分析入侵检测。

基于网络的入侵检测系统使用原始网络包作为数据包。基于网络的 IDS 通常利用一个运行在随机模式下的网络适配器来实现监视并分析通过网络的所有通信业务。它的攻击辨别模块通常采用 4 种常用技术来识别攻击技术：

- （1）模式、表达式或字节匹配。
- （2）频率或穿越阈值。
- （3）低级事件的相关性。
- （4）统计学意义上的非常规现象检测。

一旦检测到攻击行为，IDS 的响应模块将提供多种选项，以通知、报警并对攻击采取相应的反应。

基于网络的入侵检测系统主要有以下优点：

（1）拥有成本低。基于网络的 IDS 可以部署在一个或多个关键访问点来检测所有经过的网络通信。因此，基于网络的 IDS 系统并不需要安装在各种各样的主机上，从而大大减小了管理的复杂性。

（2）攻击者转移证据困难。基于网络的 IDS 使用活动的网络通信进行实时攻击检测，因此攻击者无法转移证据，被检测系统捕获的数据不仅包括攻击方法，而且包括对识别和指控入侵者十分有用的信息。

（3）实时检测和响应。一旦发生恶意访问或攻击，基于网络的 IDS 检测即可随时发现，并能够很快地做出反应。如果黑客使用 TCP 启动基于网络的拒绝服务（DoS），IDS 可以通过发送一个 TCP reset 来立即终止这个攻击，这样就可以避免目标主机遭受破坏或

崩溃。这种实时性使系统可以根据预先定义参数迅速采取相应的行动，从而将入侵活动对系统的破坏降到最低。

(4) **能够检测未成功的攻击企图。**一个置于防火墙外部的 NIDS 可以检测到旨在利用防火墙后的资源的攻击，尽管防火墙本身可能会拒绝这些攻击企图。基于主机的系统不能发现未能到达受防火墙保护的主机的攻击企图，而这些信息对于评估和改进安全策略是十分重要的。

(5) **操作系统独立。**基于网络的 IDS 并不依赖于将主机的操作系统作为检测资源，而基于主机的系统需要特定的操作系统才能发挥作用。

基于网络的入侵检测系统 (NIDS) 一般安装在需要保护的网段中，实时监视网段中传输的各种数据包，并对这些数据包进行分析和检测。如果发现入侵行为或可疑事件，入侵检测系统就会发出警报甚至切断网络连接。基于网络的入侵检测系统如同网络中的摄像机，只要在一个网络中安放一台或多台入侵检测探测器，就可以监视整个网络的运行情况，在黑客攻击造成破坏之前，预先发出警报，并通过 TCP 阻断或防火墙联动等方式，以最快的速度阻止入侵事件的发生。基于网络的入侵检测系统自成体系，它的运行不会给原系统和网络增加负担。

13.4.1 NIDS 设计

基于网络的入侵检测产品放置在比较重要的网段内，可连续监视网段中的各种数据包，对每个数据包或可疑的数据包进行特征分析。如果数据包与产品内置的某些规则吻合，入侵检测系统就会发出警报甚至直接切断网络连接。目前，大部分入侵检测产品都基于网络。NIDS 整体框架流程图如图 13-5 所示。

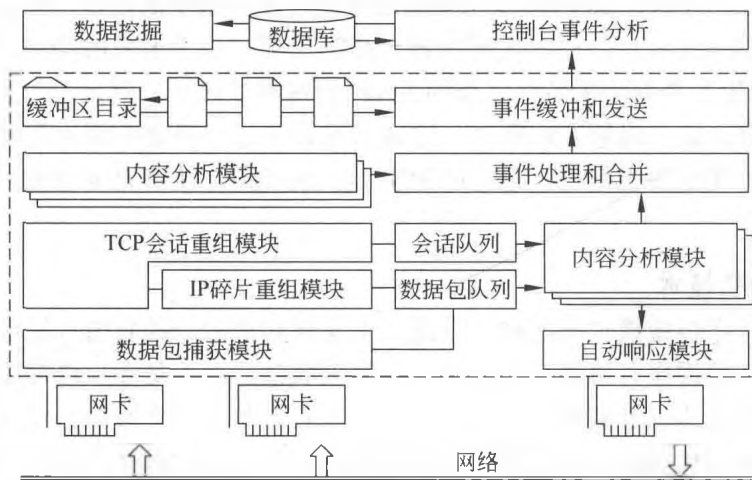


图 13-5 NIDS 整体框架流程图

在网络入侵检测系统中，有多个久负盛名的开放源码软件，它们是 Snort、NFR、Shadow、Bro、Firestorm 等，其中，Snort 的社区 (<http://www.snort.org>) 非常活跃，其入侵特征更新速度与研发的进展已超过了大部分商品化产品。可以通过分析 Snort 代码和结构来学习 NIDS 的设计。

13.4.2 NIDS 关键技术

1. IP 碎片重组技术

为了躲避入侵检测系统，攻击者往往会使用 **Fragroute** 碎片数据包转发工具，将攻击请求分成若干个 IP 碎片包发送到目标主机；目标主机接收到碎片包以后，则进行碎片重组还原出真正的请求。碎片攻击包括碎片覆盖、碎片重写、碎片超时和针对网络拓扑的碎片技术（如使用小的 TTL）等。IDS 需要在内存中缓存所有的碎片，模拟目标主机对网络上传输的碎片包进行重组，还原出真正的请求内容，然后再进行入侵检测分析。

2. TCP 流重组技术

对于入侵检测系统，最艰巨的任务是重组通过 TCP 连接交换的数据。TCP 提供了足够多的信息帮助目标系统判断数据的有效性和数据在连接中的位置。TCP 的重传机制可以确保数据准确到达，如果在一定的时间之内没有收到接收方的响应信息，发送方会自动重传数据。但是，由于监视 TCP 会话的入侵检测系统是被动的监视系统，因此无法使用 TCP 重传机制。如果在数据传输过程中发生顺序被打乱或报文丢失的情况，将加大其检测难度。更严重的是，重组 TCP 数据流需要进行序列号跟踪，但是如果在传输过程中丢失了很多报文，就可能使入侵检测系统无法进行序列号跟踪。如果没有恢复机制，就可能使入侵检测系统不能同步监视 TCP 连接。不过，即使入侵检测系统能够恢复序列号跟踪，也同样能够被攻击。

3. TCP 状态检测技术

目前，攻击 NIDS 最有效的办法是利用 Coretez Giovanni 写的 Stick 程序。Stick 使用了很巧妙的办法，可以在 2s 内模拟 450 次没有经过 3 步握手的攻击，快速告警信息的产生会让 IDS 难以做出反应，产生无反应甚至死机现象。由于未采用 TCP 状态检测技术，所以当 Stick 发出多个有攻击特征（按照 Snort 的规则组包）的数据包时，IDS 匹配了这些数据包的信息，就会频繁发出警告，造成管理者无法分辨哪些警告是针对真正的攻击发出的，从而使 IDS 失去作用。通过对 TCP 状态的检测，能够完全避免因单包匹配造成的误报。

4. 协议分析技术

协议分析是在传统模式匹配技术基础之上发展起来的一种新的入侵检测技术。协议分析的原理就是根据现有协议模式，到固定位置取值，而不是逐个进行比较，然后根据取得的值来判断其协议及实施下一步分析动作。它充分利用了网络协议的高度有序性，并结合了高速数据包捕捉、协议分析和命令解析，来快速检测是否存在某个攻击特征，这种技术正逐渐进入成熟应用阶段。协议分析大大减小了计算量，即使在高负载的高速网络上，也能逐个分析所有的数据包。

采用协议分析技术的 IDS 能够理解不同协议的原理，由此分析这些协议的流量，寻找可疑的或不正常的行为。对每一种协议的分析不仅基于协议标准，还基于协议的具体实现，因为很多协议的实现偏离了协议标准。协议分析技术观察并验证所有的流量，当

流量不是期望值时,IDS 就发出告警。协议分析具有寻找任何偏离标准或期望值的行为的能力,因此能够检测到已知和未知攻击。

状态协议分析就是在常规协议分析技术的基础上加入状态特性分析,即不仅检测单一的连接请求或响应,而是将一个会话的所有流量作为一个整体来考虑。仅靠检测单一的连接请求或响应,有些网络攻击行为是检测不到的,因为攻击行为包含在多个请求中,此时状态协议分析技术就显得十分必要。与模式匹配技术相比,协议分析和状态协议分析技术具有如下的优点。

(1) 性能提高。与模式匹配系统中传统的穷举分析方法相比,协议分析利用已知结构的通信协议在处理数据帧和连接时更迅速、有效。

(2) 准确性提高。与非智能化的模式匹配相比,协议分析减少了误警和漏警。将命令解析和协议解码技术相结合,在命令字符串到达操作系统或应用程序之前,模拟命令字符串的执行,以确定它是否具有恶意。

(3) 基于状态的分析。协议分析入侵检测系统引擎在评估某个数据包时,不仅要检查之前的相关数据包,而且还要检查之后可能出现的数据包。与此相反,模式匹配入侵检测系统只孤立地检查当前的数据包。

(4) 反规避能力大大增强。因为协议分析具有判别通信行为真实意图的能力,因此能够有效抵御利用路径模糊、十六进制编码和 Unicode 编码等进行隐藏攻击的行为。

(5) 系统资源开销小。协议分析的高效性降低了系统资源在网络和主机探测中的消耗,而模式匹配技术却能大量消耗系统资源。

5. 零复制技术

零复制的基本思想是在数据包从网络设备到用户程序空间传递的过程中,减少数据复制次数,减少系统调用,实现 CPU 的零参与,彻底消除 CPU 在这方面的负载。实现零复制用到的主要技术是 DMA 数据传输技术和内存区域映射技术。传统的网络数据报处理需要经过网络设备到操作系统内存空间、系统内存空间到用户应用程序空间这两次复制,同时还需要经历用户向系统发出的系统调用。而零复制技术则首先利用 DMA 技术将网络数据报直接传递到系统内核预先分配的地址空间中,避免 CPU 的参与;同时,将系统内核中存储数据报的内存区域映射到检测程序的应用程序空间(还有一种方式是在用户空间建立一缓存,并将其映射到内核空间,类似于 Linux 系统下的 Kiobuf 技术),检测程序直接对这块内存进行访问,从而减少系统内核向用户空间的内存复制,同时减少系统调用的开销,实现“零复制”。

零复制数据流程如图 13-6 所示,图中左侧是传统的处理网络数据包的方式。由于网卡驱动程序运行在内核空间,当网卡收到数据包后,数据包会存放在内核空间内。由于上层应用运行在用户空间,无法直接访问内核空间,因此要通过系统调用将网卡中的数据包复制到上层应用系统中,从而占用系统资源,造成 IDS 性能下降。图 13-6 右侧是改进后的网络数据包处理方式。通过重写网卡驱动,使网卡驱动与上层系统共享一块内存区域,网卡从网络上捕获到的数据包直接传递给入侵检测系统。上述过程避免了数据的内存复制,不需要占用 CPU 资源,最大程度地将有限的 CPU 资源让给协议分析和模式

匹配等进程，提高了整体性能。Luca Deri 提出一种改进数据包捕获效率的新方法，详细内容见相关参考文献。但是零复制只能解决“抓包”的瓶颈问题，实现高性能的 IDS 仍要依靠协议分析和匹配检测等其他功能模块性能的进一步加强。

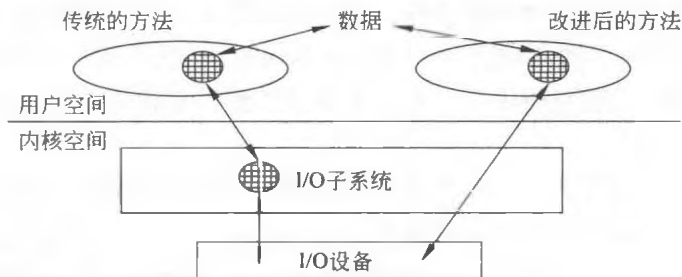


图 13-6 零复制数据流程图

6. 蜜罐技术

从传统意义上讲，信息安全意味着单纯的防御。防火墙、入侵检测系统、加密等安全机制只是用来防御，以保护用户的资源免受黑客的损害。从战术上来讲，应尽可能好地保护网络，减少安全漏洞，并对出现的安全性泄漏及时响应。这种技术的问题在于它的单纯防御特性，主动权掌握在攻击者的手中。而蜜罐技术的出现将改变这一切。现代的 IDS 采用了蜜罐（Honeypot）技术的新思想。蜜罐是一个吸引潜在攻击者的陷阱，它的作用是：

- 把潜在入侵者的注意力从关键系统移开。
- 收集入侵者的动作信息。
- 设法让攻击者停留一段时间，使管理员能检测到它并采取相应的措施。

蜜罐技术的主要目的是收集和分析现有威胁的信息。将这种技术集成到 IDS 中，我们就可以发现新的黑客工具、确定攻击的模式、研究攻击者的动机。

（1）蜜罐技术的实现

蜜罐可被视为情报收集系统。蜜罐是故意引诱攻击的目标，引诱黑客前来攻击。当攻击者入侵后，就可以知道攻击者是如何得逞的，并随时了解攻击者针对公司服务器发动的最新攻击及系统的漏洞；还可以通过窃听黑客之间的联系，收集黑客所用的各种工具并掌握黑客之间的社交网络。

设置蜜罐并不难，只要在外部的 Internet 上的一台计算机上运行有明显安全漏洞的操作系统即可，如运行一台没有打补丁的微软 Windows 或 Red Hat Linux 服务器。因为黑客可能会设陷阱，以获取计算机的日志和审查功能，所以要在计算机和 Internet 连接之间安置一套网络监控系统，以便悄悄记录进出计算机的所有流量。然后，只需坐下来，等待攻击者自投罗网。

然而，设置蜜罐并不是没有风险。这是因为，大部分安全受到威胁的系统会被黑客用来攻击其他系统。这就是下游责任（Downstream Liability），由此引出了蜜网（Honeynet）这一话题。

蜜网是指另外采用了各种入侵检测和安全审计技术的蜜罐，它可以用合理方式记录

下黑客的行动，同时尽量减小或排除对 Internet 上其他系统造成的风险。设置在反向防火墙后的蜜罐就是一个例子。防火墙的目的不是防止入站连接，而是防止蜜罐建立出站连接。不过，虽然这种方法可以使蜜罐不会破坏其他系统，但很容易被黑客发现。

数据收集是设置蜜罐的另一项技术挑战。蜜罐监控者只要记录下进出系统的每个数据包，就能够对黑客的所作所为了一清二楚。蜜罐本身的日志文件也是很好的数据来源。但日志文件很容易被攻击者删除。所以通常的办法就是让蜜罐向同一网络上防御机制较完善的远程日志服务器发送日志备份。

（2）蜜罐技术的优势

蜜罐系统的优点之一就是大大减少了所要分析的数据。对于通常的网站或邮件服务器，攻击流量通常会被合法流量所淹没，而蜜罐进出的数据大部分是攻击流量。因此，浏览数据、查明攻击者的实际行为也相对容易了。

自 1999 年启动以来，蜜网计划已经收集了大量信息，详情可访问 www.honeynet.org。信息表明：攻击率在过去一年增加了一倍；攻击者越来越多地使用能够堵住漏洞的自动点击工具（如果发现新漏洞，工具很容易更新）；尽管声势很大，但很少有黑客采用新的攻击手法。

蜜罐不仅是一种研究工具，同样有着真正的商业应用价值。将蜜罐设置在与公司网站或邮件服务器相邻的 IP 地址上，就可以了解公司网络所遭到的攻击了。

蜜罐领域最让人兴奋的发展成果之一就是出现了虚拟蜜网。虚拟计算机网络运行在使用 VMware 或 User-Mode Linux 等虚拟计算机系统的单一机器之上。虚拟系统可以在单一主机系统上运行几台虚拟计算机（通常是 4~10 台）。虚拟蜜网大大降低了蜜罐的成本及管理的难度，节省了机器占用的空间。此外，虚拟系统通常支持“悬挂”和“恢复”功能，这样就可以冻结受到安全威胁的计算机，分析攻击方法。

13.5 HIDS

HIDS 出现在 20 世纪 80 年代初期，那时网络还没有今天这样普遍、复杂，且网络之间也没有完全连通。其检测的目标主要是主机系统和本地用户。检测原理是根据主机的审计数据和系统日志发现可疑事件，检测系统可以运行在被检测的主机或单独的主机上。

在这一较为简单的环境中，最常见的操作是检查可疑行为的检测记录。由于入侵行为在当时很少见，对攻击进行事后分析就可以防止日后的攻击。

当前的 HIDS 仍使用验证记录，但自动化程度大大提高，并发展了精密的可迅速做出响应的检测技术。通常，基于主机的 IDS 可监测系统、事件和 Windows NT 下的安全记录及 UNIX 环境下的系统记录。当有文件发生变化时，IDS 将新的记录条目与攻击标记相比较，看二者是否匹配，如果匹配，系统就会向管理员报警并向其他的目标报告，以采取措施。

基于主机的入侵检测系统有以下特点：

1. 监视特定的系统活动

HIDS 监视用户和访问文件的活动，包括文件访问、改变文件权限、试图建立新的可执行文件或试图访问特殊的设备。例如，基于主机的 IDS 可以监督所有用户的登录及下网情况，以及每位用户在连接网络后的行为，而基于网络的系统要做到这种程度是非常困难的。

HIDS 还可以监视只有管理员才能实施的异常行为。操作系统记录了任何有关用户账号的增加、删除、更改的情况，一旦发生变化，基于主机的 IDS 就能检测到这种不适当的变化。基于主机的 IDS 还可审计能影响系统记录的校验措施的改变。

最后，HIDS 可以监视主要系统文件和可执行文件的改变。系统能够查出那些欲改写重要系统文件或安装特洛伊木马及后门的尝试，并将它们中断。而 NIDS 有时不会发现这些异常行为。

2. 非常适用于加密和交换环境

既然基于主机的系统驻留在网络中的主机上，那么，它们可以克服基于网络的入侵检测系统在交换和加密环境中所面临的一些困难。由于在大的交换网络中确定 IDS 的最佳位置和网络覆盖非常困难，因此基于主机的检测驻留在关键主机上可避免这一难题。

根据在加密后驻留在协议栈中的位置，NIDS 可能无法检测到某些攻击。基于主机的 IDS 并没有这个限制，因为当操作系统（也包括 HIDS）收到发来的数据包时，数据序列已经被解密。

3. 近实时的检测和应答

尽管基于主机的检测并不提供真正实时应答，但新的基于主机的检测技术已经能够提供近实时检测和应答。早期的系统主要使用一个进程来定时检测日志文件的状态和内容，而许多现有的 HIDS 在任何日志文件发生变化时，都可以从操作系统及时接收一个中断，这样就大大缩短了攻击识别和应答之间的时间。

4. 不需要额外的硬件

基于主机的检测驻留在现有的网络基础设施上，其中包括文件服务器、Web 服务器和其他的共享资源等，这样就减少了基于主机的 IDS 的实施成本；因为不需要添加新的硬件，所以也就减少了以后维护和管理这些硬件设备的负担。

13.5.1 HIDS 设计

越来越多的计算机病毒和黑客绕过外围安全设备向主机发起攻击。在检测针对主机的攻击方面，基于网络的入侵检测系统(NIDS)显得无能为力，而基于主机的 IDS(HIDS)却能够检测这种攻击。HIDS 软件安装在服务器上，也可以安装在 PC 和笔记本当中，被认为是保护关键服务器的最后一道防线，是企业整体安全策略的关键部分。

在通常情况下，企业针对服务器业务价值的大小采取不同的安全措施。HIDS 代理程序通常被部署在关键服务器上。这些服务器通常是网络基础设施服务器、业务基础设

施服务器和保存着企业商业机密的服务器。

HIDS 能够监测系统文件、进程和日志文件,寻找可疑活动。多数 HIDS 代理程序根据攻击特征来识别攻击。与防病毒软件功能类似,HIDS 代理能够分析不同形式的数据包和不同特征的攻击行为。HIDS 扫描操作系统和应用程序日志文件,查找恶意行为的痕迹;检测文件系统,查看敏感文件是否被非法访问或被篡改;检测进出主机的网络传输流,发现攻击。

黑客和病毒常用的一个攻击手段是利用关键系统存在的缓冲区溢出漏洞进行攻击。缓冲区溢出相当于打开了系统后门,为非法访问者提供了根级或管理员级的访问权限。攻击者通过操作系统的后门,将一个特洛伊木马程序复制到系统文件夹中,并将这个特洛伊文件注册到操作系统或程序调用中,并在系统被重新引导时执行该特洛伊木马程序。每当系统启动时,这个恶意的特洛伊程序就会开始执行事先定义的各种恶意活动。

通过将代理程序安装在服务器上,HIDS 可以检测缓冲区溢出攻击。如果需要,HIDS 还可以在特洛伊程序被复制时、Windows 注册表被修改时或特洛伊程序被执行时阻止入侵。

一旦检测到入侵,HIDS 代理程序可以利用多种方式做出反应。它可以生成一个与其他事件相关联的事件报告;可以利用电子邮件、呼机或手机向管理人员发出警报;可以执行特定的程序或脚本,阻止攻击。越来越多的 HIDS 能够在可疑活动的传输过程中检测到它们,从而可以在攻击到达目标之前阻止它们。

在加强主机防御和降低主机安全风险方面,HIDS 具有独特的优势。它能够弥补 NIDS、基于蜜罐的 IDS 及防火墙在保护主机方面的不足,应当成为企业多层安全战略的组成部分。

13.5.2 HIDS 关键技术

主机入侵检测系统通常在被重点检测的主机上运行一个代理程序。该代理程序扮演着检测引擎的角色,根据主机行为特征库对受检测主机上的可疑行为进行采集、分析和判断,并把告警日志发送给控制端程序,由管理员集中管理。此外,代理程序需要定期给控制端发出信号,使管理员能确信代理程序工作正常。如果是个人主机入侵检测,代理程序和控制端管理程序可以合并在一起,管理程序也简单得多。

在 Windows NT/2000 中,系统有自带的安全工具,类似于早期 Windows 版本的策略编辑器。利用这个工具可以使安全策略的规划和实施变得更加容易。安全策略问题包括账号策略、本地策略、共钥策略和 IP 安全策略。系统中违反安全策略的行为都作为事件发送给系统安全日志。主机入侵检测可以根据安全日志分析、判断入侵行为。

1. 文件和注册表保护技术

在主机入侵检测系统中,无论采用什么操作系统,普遍使用到各种钩子技术,对系统的各种事件、活动进行截获分析。在 Windows NT/2000 中,由于系统中的各种 API 子系统(如 Win32 子系统、Posix 子系统及其他系统)最终都要调用相应的系统服务例程(System Services Routines),所以可以将系统服务例程钩子化。入侵检测系统通过捕获操

作文件系统和注册表的函数来检测对文件系统和注册表的非法操作。在某些系统中，可以通过复制勾子处理函数。这不仅可以对敏感文件或目录检测非法操作，还可以阻止对文件或目录进行的操作。

2. 网络安全防护技术

网络安全防护是大多数主机入侵检测系统的核心模块之一。该模块需要使用 NDIS 等技术分析数据包的有关源地址、协议类型、访问端口和传输方向（OUT/IN）等，并与事件库中的事件特征进行匹配，判断数据包是否能访问主机或是否作为入侵事件被报警。

NDIS 是用于 Windows 系列操作系统的网络驱动程序接口。按照 NDIS 提供的接口标准，任何与 NDIS 兼容的传输驱动程序都能够和与 NDIS 兼容的网络适配器驱动程序进行信息交流。也可以采用 NDIS HOOK + WinSock2 SPI 双重技术实现更复杂、更灵活的安全防护和入侵分析功能。编写 NDIS 驱动程序，需要的技巧比较高，而且烦琐，需要考虑很多细节。有关具体的实现方法，请参见 Win2k DDK 文档。

拨号检测在主机入侵检测系统中也有其特殊用途。很多重要部门都装有内部网，出于对信息的高度安全要求，公司（或部门）不希望员工私自安装 Modem 拨号入网。安装于内部网中的带有拨号检测的主机入侵检测系统可以检测到员工的这种违规行为并及时阻止。在内部网中，如果要阻止员工侵入其他员工的系统窃取机密信息，通常需要主机入侵检测系统对不同主机中的敏感文件或目录进行检测。

3. IIS 保护技术

作为一个 WWW 服务器软件，微软公司的 Internet 信息服务器（Internet Information Server, IIS）简单易学，管理方便，被广泛使用。大部分 HIDS 产品都增加了 IIS 保护模块。IIS 保护主要是针对“HTTP 请求”、“缓冲区溢出”、“关键字”和“物理目录”等完成对 IIS 服务器的加固功能。该模块能检测常见的针对微软 IIS 服务器的攻击，并能在一定程度上预防利用未知漏洞所进行的攻击。

（1）HTTP 请求类型

指定可以到达 IIS 服务器的 HTTP 请求的类型，被禁止的请求类型将被拦截，从而使 IIS 服务不对这些请求进行处理。因为某些类型的 HTTP 请求曾被发现存在潜在的安全漏洞。

通常只需要允许 GET、POST、HEAD 类型的请求，便可以让其他人通过浏览器正常访问 IIS 网站。

（2）缓冲区溢出

攻击者通常通过工具构造出各种畸形数据包对服务器进行试探，以发现目标机器中潜在的缓冲区溢出漏洞。IIS 保护模块可以对超长的 HTTP 请求包进行检测，拦截非法的请求。

（3）关键字

对 HTTP 请求进行内容分析，禁止包含某些关键字的请求，如 cmd.exe 等。

(4) 物理目录

禁止通过 HTTP 请求进行物理目录的非法映射操作。

可以通过 ISAPI 过滤器实现上述功能,进行自己定制的处理。ISAPI 过滤器可以定制以下的处理:接收 HTTP 协议头预处理、发送 HTTP 协议头预处理、发送数据预处理、获得数据预处理、HTTP 会话结束信息处理、自定义的安全认证机制、URL 映射信息处理及日志记录处理等。

4. 文件完整性分析技术

基于主机的入侵检测系统的一个优势是可以根据结果进行判断。判据之一就是关键系统文件有没有在未经允许的情况下被修改,包括访问时间、文件大小和 MD-5 密码校验值。HIDS 一般使用杂凑函数进行文件完整性分析。有关杂凑算法的详细介绍,请参考相关的密码学教材。

主机入侵检测系统需要与现有系统紧密集成,支持的平台越多越好。目前的主流商业入侵检测系统通常支持或将支持大部分主流的企业级 Windows 和 UNIX 系统。

13.6

DIDS

在实际应用中,经常发现如下一些现象:

(1) 系统的弱点或漏洞分散在网络的各个主机上,这些弱点有可能被入侵者一起用来攻击网络,而依靠唯一的主机或网络,IDS 不能发现入侵行为。

(2) 入侵行为不再是单一的行为,而表现出协作入侵的特点,如分布式拒绝服务攻击(DDoS)。

(3) 入侵检测所依靠的数据来源分散化,收集原始数据变得困难,如交换网络使得监听网络数据包受到限制。

(4) 网络传输速度加快,网络的流量大,集中处理原始数据的方式往往造成检测瓶颈,从而导致漏检。

为了解决上述问题,DIDS 应运而生。DIDS 通常由数据采集构件、通信传输构件、入侵检测分析构件、应急处理构件和用户管理构件等组成,如图 13-7 所示。这些构件可根据不同情况组合,如数据采集构件和通信传输构件组合就产生出新的构件,这些新的构件能够完成数据采集和传输的双重任务。所有这些构件组合起来就变成一个入侵检测系统。各构件的功能如下:

(1) 数据采集构件:收集检测使用的数据,可驻留在网络中的主机上,或者安装在网络的检测点上。数据采集构件需要通信传输构件的协作,将采集的信息送到入侵检测分析构件中进行处理。

(2) 通信传输构件:传递加工、处理原始数据的控制命令,一般需要和其他构件协作完成通信功能。

(3) 入侵检测分析构件:依据检测的数据,采用检测算法,对数据进行误用分析和异常分析,产生检测结果、报警和应急信号。

（4）应急处理构件：按入侵检测的结果和主机、网络的实际情况做出决策判断，对入侵行为进行响应。

（5）用户管理构件：管理其他构件的配置，产生入侵总体报告，提供用户和其他构件的管理接口、图形化工具或可视化的界面，供用户查询和检测入侵系统的情况等。

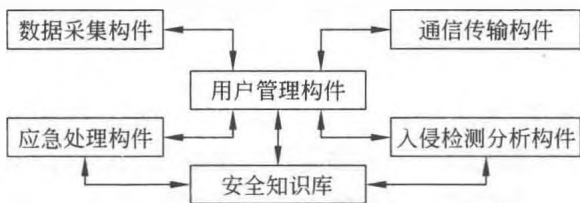


图 13-7 分布式入侵检测系统结构示意图

采用分布式结构的 IDS 目前成为研究的热点，较早的系统有 DIDS 和 CSM。DIDS 是典型的分布式结构系统，系统框图如图 13-8 所示。其目标是既能检测网络入侵行为，又能检测主机入侵行为。

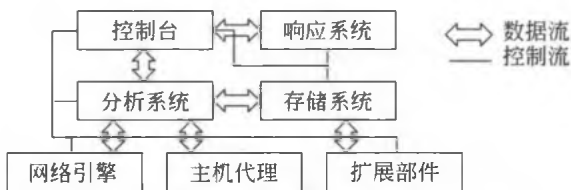


图 13-8 DIDS 系统框图

13.7 IDS 设计上的考虑与部署

13.7.1 控制台的设计

控制台通过直观、方便的操作界面管理远程探测器，汇总各个探测器报告的告警事件，并实现日志检索、备份、恢复、报表等功能。控制台的设计重点是日志检索、探测器管理、规则管理、日志报表及用户管理等。

1. 日志检索

网络管理员可以使用单一条件或复合条件进行检索，当告警日志数量庞大、来源广泛时，系统需要对告警日志按照危险等级进行分类，从而突出显示网络管理员需要的最重要信息。日志检索的条件至少包括来源地址、目标地址、来源端口、目标端口、攻击特征、风险等级、时间段等。

2. 探测器管理

控制台可以一次管理多个探测器，包括启动、停止、配置探测器和查看探测器运行状态等。

3. 规则管理

为用户提供根据不同网段具体情况灵活配置安全策略的工具，针对不同情况制定相应的安全规则。提供规则的在线和离线升级功能，设置每条规则的响应策略及允许管理自定义规则等。

另外，针对每条规则还需要提供详细的帮助信息（包括攻击类型、详细描述、风险等级、解决方案、受影响的操作系统、CVE、相关参考链接等）。

4. 日志报表

至少需要提供多种文本和图形的报表模板，且报表格式可以导出 WORD、HTML、TXT、EXCEL、PDF 等常用的格式。

5. 用户管理

对用户权限进行严格的定义，提供口令修改、添加用户、删除用户、用户权限配置等功能，有效保护系统使用的安全性。

控制台功能框图如图 13-9 所示。

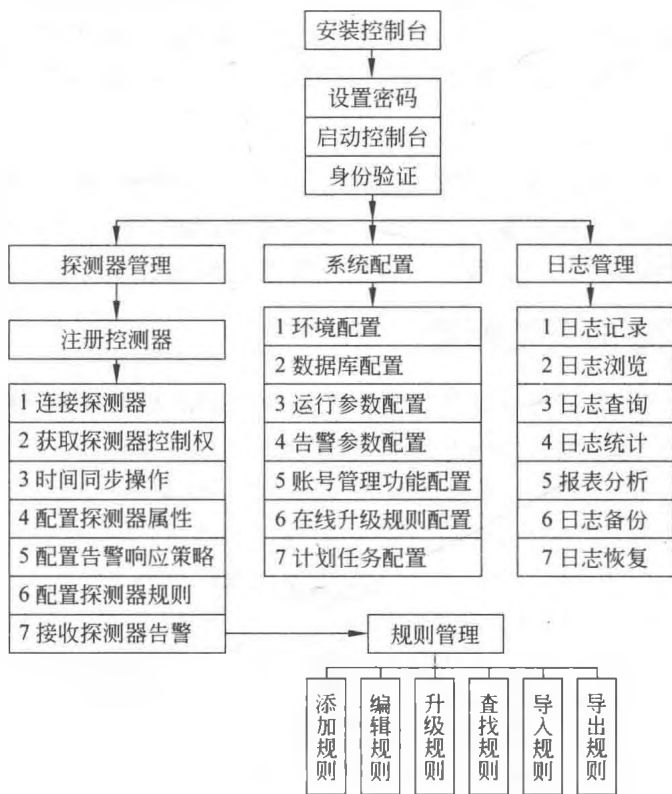


图 13-9 控制台功能框图

13.7.2 自身安全设计

计算机网络入侵检测系统部署在网络的关键节点上，捕获并记录黑客的入侵行为。这一特殊性决定它必然受到攻击者的特别关注，所以入侵检测系统自身的安全问题非常

重要。在系统设计中，需要充分考虑系统自身的安全体系结构。

1. 系统安全

计算机网络入侵检测系统部署在网络的关键节点上，通常放置在防火墙的 DMZ 中，当攻击成功通过防火墙后，该系统会识别攻击，产生告警，并通过与防火墙联动来阻断攻击。这样不仅能检测到黑客的攻击和入侵，同时又能够减少黑客的干扰。将监听网口与管理网口分离，监听网口卸掉 IP 栈使得监听网口不带任何 IP 地址，实现隐藏 IDS 探测器的目的。检测系统所在的操作系统平台安装最新的系统补丁，停止一些不必要的守护服务程序，禁止大部分远程访问权限，设置安全策略审核策略管理、登录事件等重要的系统操作，删除默认共享，禁止匿名账号等，防止黑客对 IDS 主机的攻击。

2. 认证和审计

为了防止非法用户的使用，控制台管理程序的登录必须首先进行高强度的身份认证，并且对用户的登录事件和具体操作过程进行详细的审计。在身份认证方面，密码和账号不能少于 6 位，必须是数字和字母的组合，并且密码和账号不能相同，以增加破解难度；设计账号锁定和定期修改策略，防止暴力破解。另外，最好不保存管理员密码，使用 SHA-1 等单向算法，只保存杂凑后的数据，从而保证密码的安全。在程序安全性方面，使用完整性检查功能，设置策略定期对重要文件进行完整性检查，防止程序和文件的非法篡改。

3. 通信安全

控制台和探测器之间的通信采用 TCP/IP。由于 TCP/IP 本身没有任何安全措施，通信内容有可能泄漏。为了保护控制台和探测器之间的通信，可以采用安全套接层（SSL）协议对传输的数据进行加密，实现通信数据的完整性和保密性。

13.7.3 IDS 的典型部署

在网络中部署 IDS 时，可以使用多个 NIDS 和 HIDS，这要根据网络的实际情况和自己的需求。图 13-10 是一个典型的 IDS 的部署图。

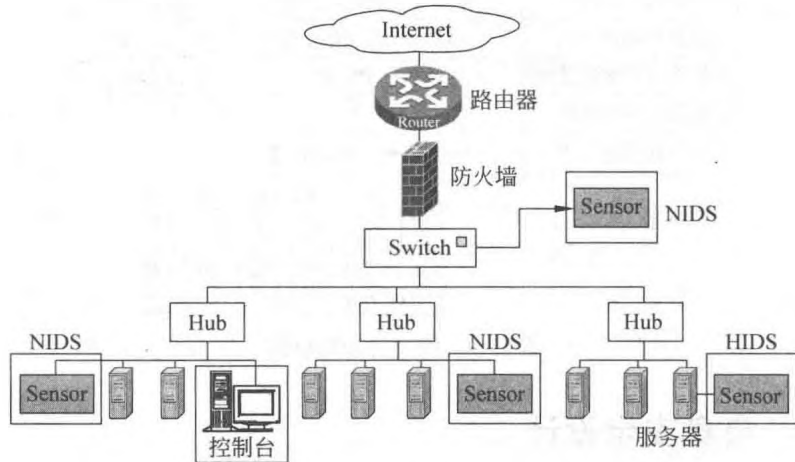


图 13-10 典型的 IDS 的部署图

13.8

IDS 的发展方向

随着网络技术和网络规模的不断发展,人们对于计算机网络的依赖也不断增强。同时,针对网络系统的攻击越来越普遍,攻击手法日趋复杂。IDS 也随着网络技术和相关学科的发展而日趋成熟,其未来发展的趋势主要表现在以下方面:

1. 宽带高速实时的检测技术

大量高速网络技术,如 ATM、千兆以太网等相继出现,在此背景下的各种宽带接入手段层出不穷。如何实现高速网络下的实时入侵检测已经成为现实面临的问题。目前的千兆 IDS 产品其性能指标与实际要求相差很远。要提高其性能主要应考虑以下两个方面:首先,IDS 的软件结构和算法需要重新设计,以期适应高速网的环境,提高运行速度和效率;其次,随着高速网络技术的不断发展与成熟,新的高速网络协议的设计也必将成为未来发展的趋势,现有 IDS 如何适应和利用未来的新网络协议将是一个全新的问题。

2. 大规模分布式的检测技术

传统的集中式 IDS 的基本模型是在网络的不同网段放置多个探测器来收集当前网络状态的信息,然后将这些信息传送到中央控制台进行处理分析。这种方式存在明显的缺陷。首先,对于大规模的分布式攻击,中央控制台的负荷将会超过其处理极限,这种情况会造成大量处理信息的遗漏,导致漏报率的增高。其次,多个探测器收集到的数据在网络上的传输会在一定程度上增加网络负担,导致网络系统性能的降低。再者,由于网络传输的时延问题,中央控制台处理的网络数据包中所包含的信息只反映了探测器接收到它时的网络状态,不能实时反映当前网络状态。

面对以上问题,新的解决方法也随之产生,例如 Purdue 大学开发的 AAFID 系统,该系统是 Purdue 大学设计的一种采用树形分层构造的代理群体,根部是监视器代理,提供全局的控制、管理,以及分析由下一层节点提供的信息,在树叶部分的代理专门用来收集信息。处在中间层的代理被称为收发器,这些收发器一方面实现对底层代理的控制,一方面可以对信息做预处理,把精练的信息反馈给上层的监视器。这种结构采用了本地代理处理本地事件,中央代理负责整体分析的模式。与集中式不同,它强调通过全体智能代理的协同工作来分析入侵策略。这种方法明显优于前者,但同时带来一些新的问题,如代理间的协作和通信等。这些问题仍在进一步研究中。

3. 数据挖掘技术

操作系统的日益复杂和网络数据流量的急剧增加,导致了审计数据以惊人速度增加,如何在海量的审计数据中提取具有代表性的系统特征模式,以及对程序 and 用户行为做出更精确的描述,是实现入侵检测的关键。

数据挖掘技术是一项通用的知识发现技术,其目的是要从海量数据中提取对用户有用的数据。将该技术用于入侵检测领域,利用数据挖掘中的关联分析、序列模式分析等算法提取相关的用户行为特征,并根据这些特征生成安全事件的分类模型,应用于安全

事件的自动鉴别。一个完整的基于数据挖掘的入侵检测模型包括对审计数据的采集、数据预处理、特征变量选取、算法比较、挖掘结果处理等一系列过程。这项技术难点在于如何根据具体应用的要求，从用于安全的先验知识出发，提取可以有效反映系统特性的特征属性，应用合适的算法进行数据挖掘。另一个技术难点在于如何将挖掘结果自动地应用到实际的IDS中。目前，国际上在这个方向上的研究很活跃，这些研究多数得到了美国国防部高级计划署、国家自然科学基金的支持。但也应看到，数据挖掘技术用于入侵检测的研究总体上来说还处于理论探讨阶段，离实际应用还有相当距离。

4. 更先进的检测算法

在入侵检测技术的发展过程中，新算法的出现可以有效提高检测效率。下述3种机器学习算法为当前检测算法的改进注入了新的活力。它们分别是计算机免疫技术、神经网络技术和遗传算法。

(1) 计算机免疫技术是直接受到生物免疫机制的启发而提出的。在生物系统中，脆弱性因素由免疫系统来处理，而这种免疫机制在处理外来异物时呈现出分布、多样性、自治及自修复等特征，免疫系统通过识别异常或以前未出现的特征来确定入侵。计算机免疫技术为入侵检测提供了一个思路，即通过正常行为的学习来识别不符合常态的行为序列。这方面的研究工作已经开展很久，但仍有待于进一步深入。

(2) 神经网络技术在入侵检测中的应用研究时间较长，并在不断发展。早期的研究通过训练后向传播神经网络来识别已知的网络入侵，进一步研究识别未知的网络入侵行为。今天的神经网络技术已经具备相当强的攻击模式分析能力，能够较好地处理带噪声的数据，而且分析速度很快，可以用于实时分析。现在提出了各种其他神经网络架构，诸如自组织特征映射网络等，以期克服后向传播网络的若干限制性缺陷。

(3) 遗传算法在入侵检测中的应用研究时间不长，在一些研究试验中，利用若干字符串序列来定义用于分析检测的命令组，用以识别正常或异常行为。这些命令在初始训练阶段不断进化，分析能力明显提高。该算法的应用还有待于进一步的研究。

5. 入侵响应技术

当IDS检测出入侵行为或可疑现象后，系统需要采取相应手段，将入侵造成的损失降至最小。系统一般可以通过生成事件告警、E-mail或短信息来通知管理员。随着网络变得日益复杂和安全要求的不断提高，更加实时的系统自动入侵响应方法正逐渐得到研究和应用。这类入侵响应大致分为3类：系统保护、动态策略和攻击对抗。这3方面都属于网络对抗的范畴，系统保护以减少入侵损失为目的；动态策略以提高系统安全性为职责；而攻击对抗则不仅可以实时保护系统，还可实现入侵跟踪和反入侵的主动防御策略。

总之，入侵检测技术作为当前网络安全研究的热点，它的快速发展和极具潜力的应用前景需要更多的研究人员参与。IDS只有在基础理论研究和工程项目开发多个层面上同时发展，才能全面提高整体检测效率。

习 题

一、填空题

1. 根据数据的来源不同, IDS 可分为_____、_____和_____3 种类型。
2. 一个通用的 IDS 模型主要由_____、_____、_____和_____4 部分组成。
3. 入侵检测一般分为 3 个步骤, 分别为_____、_____和_____。
4. 一个 NIDS 在功能结构上应至少包含_____、_____、_____和_____4 部分功能。
5. DIDS 通常由_____、_____、_____、_____和_____5 个构件组成。
6. IDS 控制台主要由_____、_____、_____、_____和_____5 个功能模块构成。
7. HIDS 常安装于_____上, 而 NIDS 常安装于_____入口处。
8. 潜在入侵者的信息可以通过检查_____日志来获得。
9. 吸引潜在攻击者的陷阱称为_____。

二、思考题

1. 入侵检测系统的定义是什么?
2. 入侵检测系统按照功能可分为哪几类? 有哪些主要功能?
3. 一个好的 IDS 应该满足哪些基本特性?
4. 常用的入侵检测统计模型有哪些?
5. 试分析基于异常与基于误用这两种检测技术的优缺点。
6. 什么是异常检测? 基于异常检测原理的入侵检测方法有哪些?
7. 什么是误用检测? 基于误用检测原理的入侵检测方法有哪些?
8. 简述 NIDS 和 HIDS 的区别, 并对各自采用的关键技术加以描述。
9. 除了异常检测和误用检测之外, 还有哪些常用的入侵检测技术?
10. 简述 NIDS 的数据流程。
11. 蜜网和蜜罐的作用是什么? 它们在检测入侵方面有什么优势?
12. IDS 在自身安全设计上应该注意哪些问题?
13. 请画出各类 IDS 在一个实际网络中的部署图。
14. 请简述 IDS 的发展方向。